LABORATUVAR 5 · PAKETPRO 3000 · Paketleme Makinesi

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad **Beyza Polat · No: 235541096** Grup **4B-Gece** Tarih **06.11.2026**

Uyarlanan makine: Özgenç Makina OMR 119 CNC Köşe Temizleme Makinesi (PVC pencere köşesindeki kaynak çapağını temizler; barkodla program yükleme + uzak servis bağlantısı)

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	PaketPro Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Evet, üç şart da sağlanıyor. (1) Bileşen VAR: OMR 119'un SBOM'unda CNC kontrol ünitesinin firmware kütüphanesi "Component X" kayıtlı. (2) Sürüm ETKİLENİYOR: makinede 2.4 kurulu, etkilenen aralıkta. (3) Açık ULAŞILABİLİR: uzak servis bağlantısı, fabrika ağı ve USB/barkodla program yükleme yolları bu kütüphaneye erişiyor.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, kendiliğinden durdurmam. Önce maruziyeti kaldırırım: uzak servis bağlantısını kapatır, makineyi ağdan ayırır, USB'yi kilitlerim; makine yerel barkod/programla çalışmaya devam eder. Ama istismar belirtisi varsa (tanımsız program, anormal eksen/bıçak hareketi) ya da koruma kapağı / acil stop zinciri etkileniyorsa makineyi hemen güvenli duruşa alırım.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test. Yamanın Özgenç Makina'dan geldiği ve imzası/hash'i doğrulanır. Test yeri: yedek kontrol ünitesi / test tezgâhı; yoksa planlı duruşta, tam yedek ve geri dönüş planıyla. Barkod → program eşleşmesi ve köşe temizleme programları deneme profilleriyle denenir, sonra üretime alınır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Yama notları ve üreticinin etki analizine bakılır: acil stop, kapak kilidi, eksen hız/konum sınırı gibi emniyet işlevlerine dokunuyor mu? Özgenç'ten yazılı beyan istenir. Emniyet devresi ayrı donanımdaysa (emniyet rölesi) etkilenmez; aynı kontrol ünitesindeyse yamadan sonra acil stop + kapak testleri tekrarlanır ve kayda geçer.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Telafi edici önlemler: uzak servis varsayılan KAPALI, yalnızca talep üzerine VPN + MFA + kişisel hesapla ve kayıtla açılır; makine ayrı VLAN / güvenlik duvarı arkasında, yalnızca program sunucusuna izin verilir; USB portları kilitli; yüklenen program dosyalarına imza/hash kontrolü; log izleme ve alarm. Kalan risk yazılı olarak kabul edilir ve yama tarihi planlanır.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · PAKETPRO 3000 · Paketleme Makinesi

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad **Beyza Polat · No: 235541096** Grup **4B-Gece** Tarih **06.11.2026**

Uyarlanan makine: Özgenç Makina OMR 119 CNC Köşe Temizleme Makinesi (PVC pencere köşesindeki kaynak çapağını temizler; barkodla program yükleme + uzak servis bağlantısı)

Senaryo: Saat **10:15**. PaketPro'nun servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu değişmiş olabilir; **ışık perdesi parametreleri henüz doğrulanmadı**. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Arayacağım kişiler: bakım/otomasyon sorumlusu, OT-BT güvenlik sorumlusu, üretim müdürü; sonra Özgenç Makina servisi. İlk üç eylem: (1) Makineyi kontrollü durdurup güvenli duruşa alırım, çalışma alanından personeli uzaklaştırırım. (2) Uzak servis bağlantısını ve ağ kablosunu fiziksel olarak ayırırım; makineyi KAPATMAM, resetlemem (kanıt kaybolmasın). (3) Olay kaydını açarım: saat, görülenler, ekran fotoğrafları.

2. **İlk 2 saat:** Egzoz güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

   Emniyet güvende mi: koruma kapağı/kilidi, acil stop ve eksen durdurma fonksiyonlarını kontrollü test ederim; emniyet parametrelerini ve CNC/barkod programlarını onaylı yedekle (hash) karşılaştırırım. Fark varsa makine kilitli kalır. Korunan kanıt: kontrol ünitesi ve alarm logları, uzak erişim/VPN ve güvenlik duvarı kayıtları, mevcut program + parametre imajı, barkod okuma geçmişi. Kapatılan: ele geçirilen servis hesabı, aynı parolayı kullanan hesaplar ve tüm açık uzak oturumlar.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Erken uyarı için (CRA yükümlülüğü üreticinindir; biz Özgenç'e bildiririz): fark edilme zamanı, etkilenen ürün (OMR 119, seri no, firmware sürümü), aktif istismar şüphesi, ilk etki (insan zararı var/yok), alınan ilk önlemler, irtibat kişisi.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden (zayıf servis parolası, sürekli açık uzak erişim?): OT güvenlik + Özgenç servis. Etki (değişen program/parametre, hatalı üretilen pencereler, emniyet etkisi): üretim + kalite. Önlem (MFA, varsayılan kapalı uzak erişim, yama): bakım + BT. Koordinasyon ve bildirim: olay sorumlusu ile üreticinin PSIRT'i.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Uzak erişim/VPN ve kimlik doğrulama logları, kontrol ünitesi olay/alarm logları, program ve parametre değişiklik geçmişi, barkod okuma kayıtları, ağ/güvenlik duvarı kayıtları, olay öncesi ve sonrası yedekler, emniyet test sonuçları, olay günlüğü ve alınan kararlar. Hepsi zaman damgalı ve değiştirilemez (hash'li) saklanır.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · PAKETPRO 3000 · Paketleme Makinesi

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad **Beyza Polat · No: 235541096** Grup **4B-Gece** Tarih **06.11.2026**

Uyarlanan makine: Özgenç Makina OMR 119 CNC Köşe Temizleme Makinesi (PVC pencere köşesindeki kaynak çapağını temizler; barkodla program yükleme + uzak servis bağlantısı)

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

*Senaryo: PaketPro'ya YZ'li görsel paket kontrolü **eklenmesi planlanıyor** — proje aşaması değerlendirmesi yapıyorsunuz.*

Kamera → YZ Modeli → OK / RED → Ret mekanizması → Hat hızı

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?
   Uyarlama: OMR 119'dan sonra, temizlenen köşede çapak kalıp kalmadığını kontrol eden YZ'li kamera. Kusurlu köşe OK aldıysa sonraki istasyona geçer, ama bu bir kalite hatasıdır; emniyet zinciri (kapak, acil stop) YZ'den bağımsız olduğu için insan zarar görmez. Önlemler: periyodik numune ile insan kontrolü, sınırdaki OK'lar için ikinci kontrol; hata oranı izlenir, eşik aşılırsa hat yavaşlar veya durur.

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?
   Nasıl fark edilir: görüntü donmuş/tekrarlanan kare, aşırı karanlık ya da parlak, zaman damgası tutarsız, kamera sinyali (heartbeat) kesik, kalibrasyon referans parçası tanınmıyor. Şüpheli girdide: otomatik OK verilmez, parça RED/karantinaya ayrılır, operatöre alarm gider, kamera sağlamlanana kadar manuel kontrole geçilir.

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?
   Eşik test verisiyle belirlenir, örneğin %95; değişikliği yalnızca yetkili kişi yapar ve kayda geçer. Eşiğin altında: parça otomatik geçmez, operatöre sorulur (human override). Düşük güvenli kararlar sıklaşırsa hat hızı düşürülür veya manuel görsel kontrole (fallback) geçilir; bu durum izlenir (monitoring).

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	Monitoring + human override: numune ile insan kontrolü, hata oranı izlenir; eşik aşılırsa hat yavaşlar/durur.
Girdi manipüle edildi	Fail-safe: şüpheli görüntüde OK verilmez; parça karantinaya ayrılır, alarm gider, manuel kontrole geçilir.
Confidence düştü	Confidence threshold + fallback: eşik (ör. %95) altındaki parça insana sorulur; sıklaşırsa manuel kontrole geçilir.

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.